

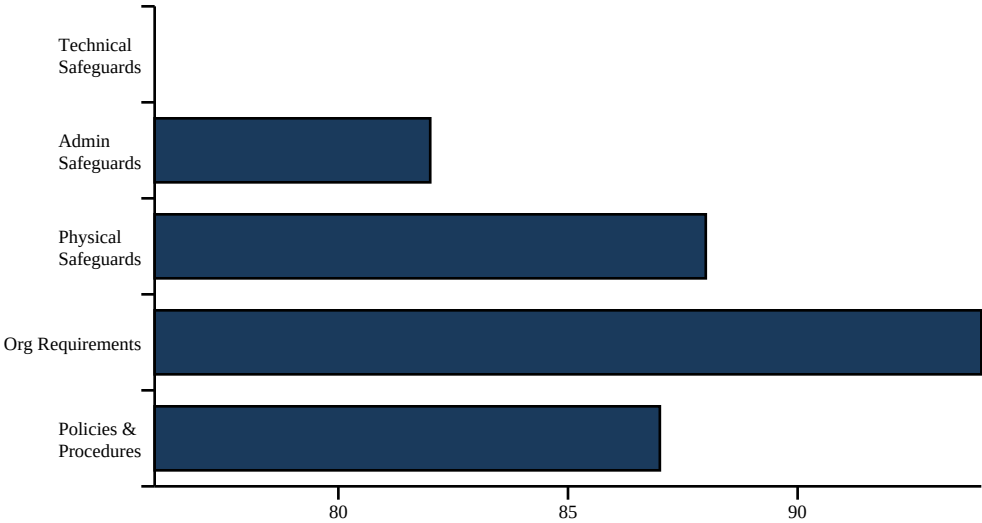
HIPAA Security Rule Compliance Checklist

Comprehensive Assessment Tool for Covered Entities and Business Associates | Annual Review
Version

Assessment Summary Dashboard

Security Domain	Total Controls	Compliant	Partial	Non-Compliant	Score
Administrative Safeguards	42	32	6	4	82%
Physical Safeguards	24	20	2	2	88%
Technical Safeguards	31	22	5	4	76%
Organizational Requirements	8	7	1	0	94%
Policies & Procedures	15	12	2	1	87%
TOTAL	120	93	16	11	83%

HIPAA Security Rule Compliance Score by Domain (%)



Section 1 — Administrative Safeguards (45 CFR §164.308)

1.1 Security Management Process (Required)

Control	Standard	Status	Finding	Recommendation
164.308(a)(1)(ii)(A)	Risk Analysis	■ Compliant	Annual risk analysis conducted Aug 2023 due Aug 2024	
164.308(a)(1)(ii)(B)	Risk Management	■■ Partial	Plan exists but lacks measurable milestones and tracking	Address
164.308(a)(1)(ii)(C)	Sanction Policy	■ Compliant	Policy documented, applied consistently	Review annually
164.308(a)(1)(ii)(D)	Info System Review	■ Gap	No formal log review process	Implement SIEM solution

1.2 Workforce Security (Required/Addressable)

Control	Standard	Status	Last Verified
164.308(a)(3)(ii)(A)	Authorization/Supervision	■ Compliant	Q3 2023
164.308(a)(3)(ii)(B)	Workforce Clearance	■■ Partial	Background checks not for contractors
164.308(a)(3)(ii)(C)	Termination Procedures	■ Compliant	Automated via HR system
Access Reviews	(Best practice)	■■ Partial	Done annually, recommend semi-annual

Section 2 — Technical Safeguards (45 CFR §164.312)

Control	Ref	Required/Addressable	Implementation	Status
Unique User IDs	164.312(a)(2)(i)	Required	Active Directory UPNs	■
Emergency Access	164.312(a)(2)(ii)	Required	Break-glass procedure documented	■
Automatic Logoff	164.312(a)(2)(iii)	Addressable	15-min timeout on all endpoints	■
Encryption/Decryption	164.312(a)(2)(iv)	Addressable	AES-256 at rest, TLS 1.3 in transit	■
Audit Controls	164.312(b)	Required	SIEM deployed, 90-day retention	■■
Integrity Controls	164.312(c)(1)	Required	Hash verification on backups	■
Auth Mechanisms	164.312(d)	Required	MFA enforced for all users	■
Transmission Security	164.312(e)(1)	Required	VPN + TLS enforced	■

Section 3 — Remediation Priority Matrix

Finding	Risk Level	Effort	Priority	Target Date
No formal SIEM/log review	HIGH	HIGH	P1	Q1 2024
Contractor background checks missing	HIGH	MEDIUM	P1	Q1 2024
Risk management KPIs absent	MEDIUM	LOW	P2	Q2 2024
Semi-annual access reviews	MEDIUM	MEDIUM	P2	Q2 2024
Audit log retention <180 days	MEDIUM	MEDIUM	P2	Q2 2024
BCP test documentation gaps	LOW	LOW	P3	Q3 2024